

模擬問題

選りすぐりの過去問題とその解説を掲載しています。本書を学習する前に試験の概要を把握する目的や、学習の終盤に理解度を把握する目的で、この模擬問題に取り組んでみましょう。

科目A（問1～問48）は、情報セキュリティマネジメント試験の過去問題にとどまらず、基本情報技術者試験・応用情報技術者試験・情報処理安全確保支援士試験などの過去問題も多く盛り込み、難しい問題にも対応できるようにしています。

科目B（問49～問60）は、情報セキュリティマネジメント試験・応用情報技術者試験・情報処理安全確保支援士試験などの午後問題をもとに、科目Bの形式にあわせて改題しています。

▶ 模擬問題 〈科目A〉



問1 JIS Q 27000:2014（情報セキュリティマネジメントシステム—用語）において定義されている情報セキュリティの特性に関する記述のうち、否認防止の特性に関する記述はどれか。 （解説p.463）

- ア ある利用者があるシステムを利用したという事実が証明可能である。
- イ 認可された利用者が要求したときにアクセスが可能である。
- ウ 認可された利用者に対してだけ、情報を使用させる又は開示する。
- エ 利用者の行動と意図した結果とが一貫性をもつ。

問2 Web アプリケーションのセッションが攻撃者に乗っ取られ、攻撃者が乗っ取ったセッションを利用してアクセスした場合でも、個人情報の漏えいなどの被害が拡大しないようにするために、Web アプリケーションが重要な情報をWeb ブラウザに送信する直前に行う対策として、最も適切なものはどれか。 （解説p.463）

- ア Web ブラウザとの間の通信を暗号化する。
- イ 発行済セッションIDをCookieに格納する。
- ウ 発行済セッションIDをURLに設定する。
- エ パスワードによる利用者認証を行う。

問3 ドメイン名ハイジャックを可能にする手口はどれか。 （解説p.463）

- ア PCとWebサーバとの通信を途中で乗っ取り、不正にデータを窃取する。
- イ Webサーバに、送信元を偽装したリクエストを大量に送信して、Webサービスを停止させる。
- ウ Webページにアクセスする際のURLに余分なドットやスラッシュなどを含め、アクセスが禁止されているディレクトリにアクセスする。
- エ 権威DNSサーバに登録された情報を不正に書き換える。

問4 インターネットバンキングの利用時に被害をもたらすMITB (Man-in-the-Browser) 攻撃に有効なインターネットバンクでの対策はどれか。 (解説p.464)

- ア インターネットバンキングでの送金時に接続するWebサイトの正当性を確認できるよう、EV SSLサーバ証明書を採用する。
- イ インターネットバンキングでの送金時に利用者が入力した情報と、金融機関が受信した情報とに差異がないことを検証できるよう、トランザクション署名を利用する。
- ウ インターネットバンキングでのログイン認証において、一定時間ごとに自動的に新しいパスワードに変更されるワンタイムパスワードを導入する。
- エ インターネットバンキング利用時の通信をSSLではなくTLSを利用して暗号化するようにWebサイトを設定する。

問5 サーバへのログイン時に用いるパスワードを不正に取得しようとする攻撃とその対策の組合せのうち、適切なものはどれか。 (解説p.464)

	辞書攻撃	スニффイング	ブルートフォース攻撃
ア	推測されにくいパスワードを設定する。	パスワードを暗号化して送信する。	ログインの試行回数に制限を設ける。
イ	推測されにくいパスワードを設定する。	ログインの試行回数に制限を設ける。	パスワードを暗号化して送信する。
ウ	パスワードを暗号化して送信する。	ログインの試行回数に制限を設ける。	推測されにくいパスワードを設定する。
エ	ログインの試行回数に制限を設ける。	推測されにくいパスワードを設定する。	パスワードを暗号化して送信する。

問6 ディレクトリトラバーサル攻撃に該当するものはどれか。 (解説p.464)

- ア 攻撃者が、Webアプリケーションの入力データとしてデータベースへの命令文を構成するデータを入力し、管理者の意図していないSQL文を実行させる。
- イ 攻撃者が、パス名を使ってファイルを指定し、管理者の意図していないファイルを不正に閲覧する。
- ウ 攻撃者が、利用者をWebサイトに誘導した上で、WebアプリケーションによるHTML出力のエスケープ処理の欠陥を悪用し、利用者のWebブラウザで悪意のあるスクリプトを実行させる。
- エ セッションIDによってセッションが管理されるとき、攻撃者がログイン中の利用者のセッションIDを不正に取得し、その利用者になりすましてサーバにアクセスする。

問7 BEC (Business E-mail Compromise) に該当するものはどれか。 (解説p.465)

- ア 巧妙なだましの手口を駆使し、取引先になりすまして偽の電子メールを送り、金銭をだまし取る。
- イ 送信元を攻撃対象の組織のメールアドレスに詐称し、多数の実在しないメールアドレスに一度に大量の電子メールを送り、攻撃対象の組織のメールアドレスを故意にブラックリストに登録させて、利用を阻害する。
- ウ 第三者からの電子メールが中継できるように設定されたメールサーバを、スパムメールの中継に悪用する。
- エ 誹謗中傷メールの送信元を攻撃対象の組織のメールアドレスに詐称し、組織の社会的な信用を大きく損なわせる。

問8 DNS キャッシュサーバに対して外部から行われるキャッシュポイズニング攻撃への対策のうち、適切なものはどれか。 (解説p.465)

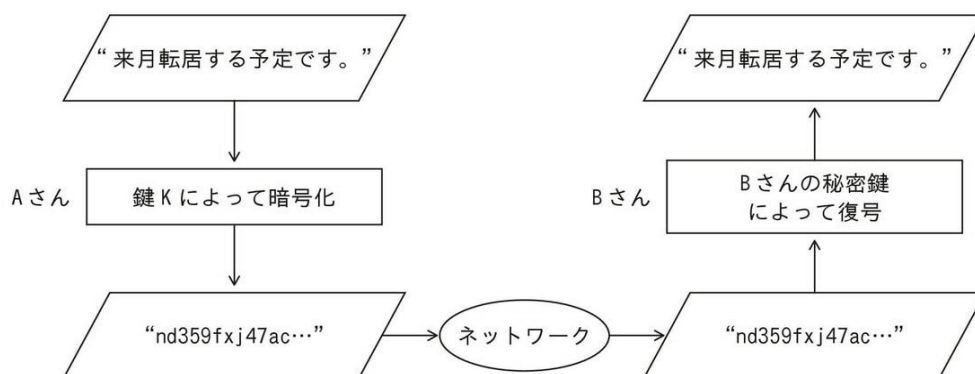
- ア 外部ネットワークからの再帰的な問合せに応答できるように、コンテンツサーバにキャッシュサーバを兼ねさせる。
- イ 再帰的な問合せに対しては、内部ネットワークからのものだけに応答するように設定する。
- ウ 再帰的な問合せを行う際の送信元のポート番号を固定する。
- エ 再帰的な問合せを行う際のトランザクション ID を固定する。

問9 ゼロデイ攻撃の特徴はどれか。 (解説p.465)

- ア 脆弱性に対してセキュリティパッチが提供される前に当該脆弱性を悪用して攻撃する。
- イ 特定のWebサイトに対し、日時を決めて、複数台のPCから同時に攻撃する。
- ウ 特定のターゲットに対し、フィッシングメールを送信して不正サイトに誘導する。
- エ 不正中継が可能なメールサーバを見つけて、それを踏み台にチェーンメールを大量に送信する。

問10 公開鍵暗号方式を用いて、図のようにAさんからBさんへ、他人に秘密にしておきたい文章を送るとき、暗号化に用いる鍵Kとして、適切なものはどれか。

(解説p.465)



- ア Aさんの公開鍵
ウ Bさんの公開鍵

- イ Aさんの秘密鍵
エ 共通鍵

問11 手順に示す電子メールの送受信によって得られるセキュリティ上の効果はどれか。

(解説p.466)

〔手順〕

- (1) 送信者は、電子メールの本文を共通鍵暗号方式で暗号化し（暗号文）、その共通鍵を受信者の公開鍵を用いて公開鍵暗号方式で暗号化する（共通鍵の暗号化データ）。
- (2) 送信者は、暗号文と共通鍵の暗号化データを電子メールで送信する。
- (3) 受信者は、受信した電子メールから取り出した共通鍵の暗号化データを、自分の秘密鍵を用いて公開鍵暗号方式で復号し、得た共通鍵で暗号文を復号する。

- ア 送信者による電子メールの送達確認
イ 送信者のなりすましの検出
ウ 電子メールの本文の改ざん箇所の修正
エ 電子メールの本文の内容の漏えいの防止

問12 パスワードを用いて利用者を認証する方法のうち、適切なものはどれか。

(解説p.466)

- ア パスワードに対応する利用者IDのハッシュ値を登録しておき、認証時に入力されたパスワードをハッシュ関数で変換して比較する。
- イ パスワードに対応する利用者IDのハッシュ値を登録しておき、認証時に入力された利用者IDをハッシュ関数で変換して比較する。
- ウ パスワードをハッシュ値に変換して登録しておき、認証時に入力されたパスワードをハッシュ関数で変換して比較する。
- エ パスワードをハッシュ値に変換して登録しておき、認証時に入力された利用者IDをハッシュ関数で変換して比較する。

問13 ワームの検知方式の一つとして、検査対象のファイルからSHA-256を使ってハッシュ値を求め、既知のワーム検体ファイルのハッシュ値のデータベースと照合する方式がある。この方式によって、検知できるものはどれか。 (解説p.466)

- ア ワーム検体と同一のワーム
- イ ワーム検体と特徴あるコード列が同じワーム
- ウ ワーム検体とファイルサイズが同じワーム
- エ ワーム検体の亜種に該当するワーム

問14 デジタル証明書をもつA氏が、B商店に対して電子メールを使って商品を注文するときに、A氏は自分の秘密鍵を用いてデジタル署名を行い、B商店はA氏の公開鍵を用いて署名を確認する。この手法によって実現できることはどれか。ここで、A氏の秘密鍵はA氏だけが使用できるものとする。 (解説p.467)

- ア A氏からB商店に送られた注文の内容が、第三者に漏れないようにできる。
- イ A氏から発信された注文が、B商店に届くようにできる。
- ウ B商店からA氏への商品販売が許可されていることを確認できる。
- エ B商店に届いた注文が、A氏からの注文であることを確認できる。

問15 XML 署名を利用することによってできることはどれか。

(解説 p.467)

- ア TLSにおいて、HTTP 通信の暗号化及び署名の付与に利用することによって、通信経路上でのXML ファイルの盗聴を防止する。
- イ XML と JavaScript がもつ非同期のHTTP 通信機能を使い、Web ページの内容を動的に書き換えた上で署名を付与することによって、対話型のWeb ページを作成する。
- ウ XML 文書全体に対する単一の署名だけではなく、文書の一部に対して署名を付与する部分署名や多重署名などの複雑な要件に対応する。
- エ 隠したい署名データを画像データの中に埋め込むことによって、署名の存在自体を外から判別できなくする。

問16 リスクベース認証に該当するものはどれか。

(解説 p.467)

- ア インターネットからの全てのアクセスに対し、トークンで生成されたワンタイムパスワードを入力させて認証する。
- イ インターネットバンキングでの連続する取引において、取引の都度、乱数表の指定したマス目にある英数字を入力させて認証する。
- ウ 利用者のIP アドレスなどの環境を分析し、いつもと異なるネットワークからのアクセスに対して追加の認証を行う。
- エ 利用者の記憶、持ち物、身体の特徴のうち、必ず二つ以上の方式を組み合わせる認証する。

問17 ソフトウェアの脆弱性^{ぜい}管理のためのツールとしても利用されるSBOM (Software Bill of Materials) はどれか。

(解説 p.467)

- ア ソフトウェアの脆弱性に対する、ベンダーに依存しないオープンで汎用的な深刻度の評価方法
- イ ソフトウェアのセキュリティアップデートを行うときに推奨される管理プロセス、組織体制などをまとめたガイドライン
- ウ ソフトウェアを構成するコンポーネント、互いの依存関係などのリスト
- エ 米国の非営利団体MITRE によって策定された、ソフトウェアにおけるセキュリティ上の弱点の種類を識別するための基準

問18 プロジェクトマネジメントにおけるリスクの対応例のうち、PMBOKのリスク対応戦略の一つである転嫁に該当するものはどれか。
(解説p.468)

- ア あるサブプロジェクトの損失を、他のサブプロジェクトの利益と相殺する。
- イ 個人情報の漏えいが起こらないように、システムテストで使用する本番データの個人情報部分はマスキングする。
- ウ 損害の発生に備えて、損害賠償保険を掛ける。
- エ 取引先の業績が悪化して、信用に不安があるので、新規取引を止める。

問19 JIS Q 27002:2014には記載されていないが、JIS Q 27017:2016において記載されている管理策はどれか。
(解説p.468)

- ア クラウドサービス固有の情報セキュリティ管理策
- イ 事業継続マネジメントシステムにおける管理策
- ウ 情報セキュリティガバナンスにおける管理策
- エ 制御システム固有のサイバーセキュリティ管理策

問20 情報セキュリティ管理を推進する取組みa～dのうち、IPA“中小企業の情報セキュリティ対策ガイドライン（第2.1版）”において、経営者がリーダーシップを発揮し自ら行うべき取組みとして示されているものだけを全て挙げた組合せはどれか。
(解説p.468)

〔情報セキュリティ管理を推進する取組み〕

- a 情報セキュリティ監査の目的を有効かつ効率的に達成するために、監査計画を立案する。
- b 情報セキュリティ対策の有効性を維持するために、対策を定期又は随時に見直す。
- c 情報セキュリティ対策を組織的に実施する意思を明確に示すために、方針を定める。
- d 情報セキュリティの新たな脅威に備えるために、最新動向を収集する。

- ア a, b, c イ a, b, d ウ a, c, d エ b, c, d

問21 リスクの顕在化に備えて地震保険に加入するという対応は、JIS Q 31000:2010に示されているリスク対応のうち、どれに分類されるか。
(解説p.469)

- ア ある機会を追求するために、そのリスクを取る又は増加させる。
- イ 一つ以上の他者とそのリスクを共有する。
- ウ リスク源を除去する。
- エ リスクを生じさせる活動を開始又は継続しないと決定することによって、リスクを回避する。

問22 JIS Q 31000:2010（リスクマネジメントー原則及び指針）において、リスクマネジメントは、“リスクについて組織を指揮統制するための調整された活動”と定義されている。そのプロセスを構成する活動の実行順序として、適切なものはどれか。
(解説p.469)

- ア リスク特定→リスク対応→リスク分析→リスク評価
- イ リスク特定→リスク分析→リスク評価→リスク対応
- ウ リスク評価→リスク特定→リスク分析→リスク対応
- エ リスク評価→リスク分析→リスク特定→リスク対応

問23 自社製品の脆弱性^{ぜい}に起因するリスクに対応するための社内機能として、最も適切なものはどれか。
(解説p.469)

- | | |
|---------|----------------------|
| ア CSIRT | イ PSIRT |
| ウ SOC | エ WHOISデータベースの技術連絡担当 |

問24 総務省及び国立研究開発法人情報通信研究機構（NICT）が2019年2月から実施している取組“NOTICE”に関する記述のうち、適切なものはどれか。（解説p.470）

- ア NICTが運用するダークネット観測網において、マルウェアに感染したIoT機器から到達するパケットを分析した結果を当該機器の製造者に提供し、国内での必要な対策を促す。
- イ 国内のグローバルIPアドレスを有するIoT機器に対して、容易に推測されるパスワードを入力することなどによって、サイバー攻撃に悪用されるおそれのある機器を調査し、インターネットサービスプロバイダを通じて当該機器の利用者に注意喚起を行う。
- ウ 国内の利用者からの申告に基づき、利用者の所有するIoT機器に対して無料でリモートから、侵入テストやOSの既知の脆弱性の有無の調査を実施し、結果を通知するとともに、利用者が自ら必要な対処ができるよう支援する。
- エ 製品のリリース前に、不要にもかかわらず開放されているポートの存在、パスワードの設定漏れなど約200項目の脆弱性の有無を調査できるテストベッドを国内のIoT機器製造者向けに公開し、市場に流通するIoT機器のセキュリティ向上を目指す。

問25 経済産業省が“サイバー・フィジカル・セキュリティ対策フレームワーク（Version 1.0）”を策定した主な目的の一つはどれか。（解説p.470）

- ア ICTを活用し、場所や時間を有効に活用できる柔軟な働き方（テレワーク）の形態を示し、テレワークの形態に応じた情報セキュリティ対策の考え方を示すこと
- イ 新たな産業社会において付加価値を創造する活動が直面するリスクを適切に捉えるためのモデルを構築し、求められるセキュリティ対策の全体像を整理すること
- ウ クラウドサービスの利用者と提供者が、セキュリティ管理策の実施について容易に連携できるように、実施の手引を利用者向けと提供者向けの対で記述すること
- エ データセンタの利用者と事業者に対して“データセンタの適切なセキュリティ”とは何かを考え、共有すべき知見を提供すること

問26 IT製品及びシステムが、必要なセキュリティレベルを満たしているかどうかについて、調達者が判断する際に役立つ評価結果を提供し、独立したセキュリティ評価結果間の比較を可能にするための規格はどれか。 (解説p.471)

- | | |
|-----------------|-----------------|
| ア ISO/IEC 15408 | イ ISO/IEC 27002 |
| ウ ISO/IEC 27017 | エ ISO/IEC 30147 |

問27 PCI DSS v3.2.1において、取引承認を受けた後の加盟店及びサービスプロバイダにおけるカードセキュリティコードの取扱方法の組みのうち、適切なものはどれか。ここで、用語の定義は次のとおりとする。(解説p.471)

〔用語の定義〕

加盟店とは、クレジットカードを商品又はサービスの支払方法として取り扱う事業体をいう。サービスプロバイダとは、他の事業体の委託でカード会員データの処理、保管、伝送に直接関わる事業体をいう。イシュー（クレジットカード発行や発行サービスを行う事業体）は除く。

カードセキュリティコードには、カード表面又は署名欄に印字されている、3桁又は4桁の数値がある。

	加盟店におけるカードセキュリティコードの取扱方法	サービスプロバイダにおけるカードセキュリティコードの取扱方法
ア	暗号化して加盟店内に保管する。	暗号化してサービスプロバイダのシステム内に保管する。
イ	平文で加盟店内に保管する。	保管しない。
ウ	保管しない。	平文でサービスプロバイダのシステム内に保管する。
エ	保管しない。	保管しない。

問28 CSIRTの説明として、適切なものはどれか。

(解説p.472)

- ア 企業や行政機関などに設置され、コンピュータセキュリティインシデントに対応する活動を行う組織
- イ 事業者が個人情報について適切な保護措置を講じる体制を整備・運用しており、かつ、JIS Q 15001に適合していることを認定する組織
- ウ 電子政府のセキュリティを確保するために、安全性及び実装性に優れると判断される暗号技術を選出する組織
- エ 内閣官房に設置され、サイバーセキュリティ政策に関する総合調整を行いつつ、“自由、公正かつ安全なサイバー空間”の創出に向け、官民一体となって様々な活動に取り組む組織

問29 システム管理者に対する施策のうち、IPA“組織における内部不正防止ガイドライン”に照らして、内部不正防止の観点から適切なものはどれか。

(解説p.472)

- ア システム管理者間の会話・情報交換を制限する。
- イ システム管理者の操作履歴を本人以外が閲覧することを制限する。
- ウ システム管理者の長期休暇取得を制限する。
- エ 夜間・休日のシステム管理者の単独作業を制限する。

問30 データベースのアカウントの種類とそれに付与する権限の組合せのうち、情報セキュリティ上、適切なものはどれか。

(解説p.472)

	アカウントの種類	レコードの 更新権限	テーブルの 作成・削除権限
ア	データ構造の定義用アカウント	有	無
イ	データ構造の定義用アカウント	無	有
ウ	データの入力・更新用アカウント	有	有
エ	データの入力・更新用アカウント	無	有

問31 不正が発生する際には“不正のトライアングル”の3要素全てが存在すると考えられている。“不正のトライアングル”の構成要素の説明として、適切なものはどれか。
(解説p.473)

- ア “機会”とは、情報システムなどの技術や物理的な環境、組織のルールなど、内部者による不正行為の実行を可能又は容易にする環境の存在である。
- イ “情報と伝達”とは、必要な情報が識別、把握及び処理され、組織内外及び関係者相互に正しく伝えられるようにすることである。
- ウ “正当化”とは、ノルマによるプレッシャなどのことである。
- エ “動機”とは、良心のかしゃくを乗り越える都合の良い解釈や他人への責任転嫁など、内部者が不正行為を自ら納得させるための自分勝手な理由付けである。

問32 軽微な不正や犯罪を放置することによって、より大きな不正や犯罪が誘発されるという理論はどれか。
(解説p.473)

- | | |
|-----------------|----------|
| ア 環境設計による犯罪予防理論 | イ 日常活動理論 |
| ウ 不正のトライアングル理論 | エ 割れ窓理論 |

問33 受信した電子メールの送信元ドメインが詐称されていないことを検証する仕組みであるSPF (Sender Policy Framework) の特徴はどれか。
(解説p.473)

- ア 受信側のメールサーバが、受信メールの送信元IPアドレスから送信元ドメインを検索してDNSBLに照会する。
- イ 受信側のメールサーバが、受信メールの送信元IPアドレスと、送信元ドメインのDNSに登録されているメールサーバのIPアドレスとを照合する。
- ウ 受信側のメールサーバが、受信メールの送信元ドメインから送信元メールサーバのIPアドレスを検索してDNSBLに照会する。
- エ メール受信者のPCが、送信元ドメインから算出したハッシュ値と受信メールに添付されているハッシュ値とを照合する。

問34 機密ファイルが格納されていて、正常に動作するPCの磁気ディスクを産業廃棄物処理業者に引き渡して廃棄する場合の情報漏えい対策のうち、適切なものはどれか。
(解説p.474)

- ア 異なる圧縮方式で、機密ファイルを複数回圧縮する。
- イ 専用の消去ツールで、磁気ディスクのマスタブートレコードを複数回消去する。
- ウ ランダムなビット列で、磁気ディスクの全領域を複数回上書きする。
- エ ランダムな文字列で、機密ファイルのファイル名を複数回変更する。

問35 ファイルの属性情報として、ファイルに対する読取り、書込み、実行の権限を独立に設定できるOSがある。この3種類の権限は、それぞれに1ビットを使って許可、不許可を設定する。この3ビットを8進数表現0～7の数字で設定するとき、次の試行結果から考えて、適切なものはどれか。
(解説p.474)

〔試行結果〕

- ① 0を設定したら、読取り、書込み、実行ができなくなってしまった。
- ② 3を設定したら、読取りと書込みはできたが、実行ができなかった。
- ③ 7を設定したら、読取り、書込み、実行ができるようになった。

- ア 2を設定すると、読取りと実行ができる。
- イ 4を設定すると、実行だけができる。
- ウ 5を設定すると、書込みだけができる。
- エ 6を設定すると、読取りと書込みができる。

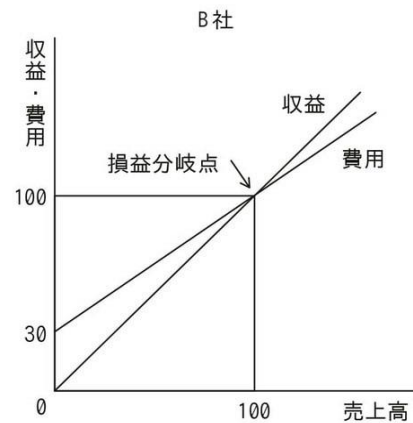
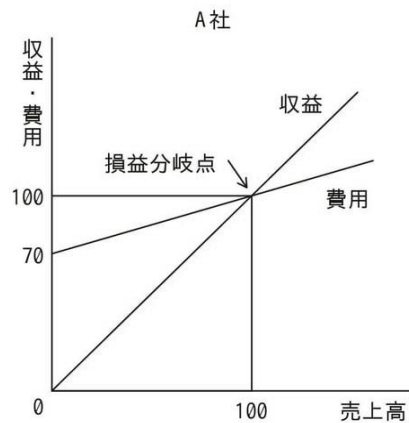
問39 情報セキュリティに係るリスクマネジメントが効果的に実施されるよう、リスクアセスメントに基づいた適切なコントロールの整備、運用状況を検証又は評価し、保証又は助言を与えるものであり、実施者に独立かつ専門的な立場が求められるものはどれか。 (解説p.478)

- ア コントロールセルフアセスメント (CSA)
- イ 情報セキュリティ監査
- ウ 情報セキュリティ対策ベンチマーク
- エ デジタルフォレンジックス

問40 非機能要件の定義で行う作業はどれか。 (解説p.478)

- ア 業務を構成する機能間の情報（データ）の流れを明確にする。
- イ システム開発で用いるプログラム言語に合わせた開発基準、標準の技術要件を作成する。
- ウ システム機能として実現する範囲を定義する。
- エ 他システムとの情報授受などのインタフェースを明確にする。

問41 図は二つの会社の損益分岐点を示したものである。A社とB社の損益分析に関する記述のうち、適切なものはどれか。 (解説p.479)



- ア A社、B社ともに損益分岐点を越えた等しい売上高のとき、固定費の少ないB社の方がA社よりも利益が大きい。
- イ A社はB社より変動費率が小さいので、損益分岐点を越えた等しい売上高のとき、B社に比べて利益が大きい。
- ウ 両社の損益分岐点は等しいので、等しい利益を生み出すために必要な売上高は両社とも等しい。
- エ 両社は損益分岐点が等しく、固定費も等しいので、売上高が等しければ、損益も等しい。

問42 次の契約条件でコストプラスインセンティブフィー契約を締結した。完成時の実コストが8,000万円の場合、受注者のインセンティブフィーは何万円か。

(解説p.480)

〔契約条件〕

- (1) 目標コスト
9,000万円
- (2) 目標コストで完成したときのインセンティブフィー
1,000万円
- (3) 実コストが目標コストを下回ったときのインセンティブフィー
目標コストと実コストとの差額の70%を1,000万円に加えた額。
- (4) 実コストが目標コストを上回ったときのインセンティブフィー
実コストと目標コストとの差額の70%を1,000万円から減じた額。
ただし、1,000万円から減じる額は、1,000万円を限度とする。

ア 700 イ 1,000 ウ 1,400 エ 1,700

問43 3Dセキュア2.0 (EMV 3-D セキュア) は、オンラインショッピングにおけるクレジットカード決済時に、不正取引を防止するための本人認証サービスである。3Dセキュア2.0で利用される本人認証の特徴はどれか。
(解説p.480)

- ア 利用者がカード会社による本人認証に用いるパスワードを忘れた場合でも、安全にパスワードを再発行することができる。
- イ 利用者の過去の取引履歴や決済に用いているデバイスの情報から不正利用や高リスクと判断される場合に、カード会社が追加の本人認証を行う。
- ウ 利用者の過去の取引履歴や決済に用いているデバイスの情報にかかわらず、カード会社がパスワードと生体認証を併用した本人認証を行う。
- エ 利用者の過去の取引履歴や決済に用いているデバイスの情報に加えて、操作しているのが人間であることを確認した上で、カード会社が追加の本人認証を行う。

問44 エンベロープ暗号化の説明はどれか。

(解説p.481)

- ア 暗号化鍵で平文を暗号化してから、その暗号化鍵を別の暗号化鍵で暗号化する。
- イ 暗号化メールを送信する際に、送信者が電子メールの返信先メールアドレスを設定する。
- ウ 公開鍵暗号方式を利用し、電子メールの受信者の公開鍵でメール本文を暗号化する。
- エ 光の最小単位である光子1個1個に1ビットのデータを載せて送り、受信した光子の数を確認することによって盗聴を発見できる。

問45 不良品の個数を製品別に集計すると表のようになった。ABC分析を行って、まずA群の製品に対策を講じることにした。A群の製品は何種類か。ここで、A群は70%以上とする。

(解説p.481)

製品	P	Q	R	S	T	U	V	W	X	合計
個数	182	136	120	98	91	83	70	60	35	875

- ア 3
- イ 4
- ウ 5
- エ 6

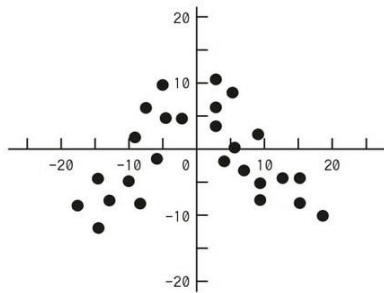
問46 工程管理図表に関する記述のうち、ガントチャートの特徴はどれか。(解説p.482)

- ア 工程管理上の重要ポイントを期日として示しておき、意思決定しなければならない期日が管理できる。
- イ 個々の作業の順序関係、所要日数、余裕日数などが把握できる。
- ウ 作業開始と作業終了の予定と実績や、仕掛かり中の作業などが把握できる。
- エ 作業の出来高の時間的な推移を表現するのに適しており、費用管理と進捗管理が同時に行える。

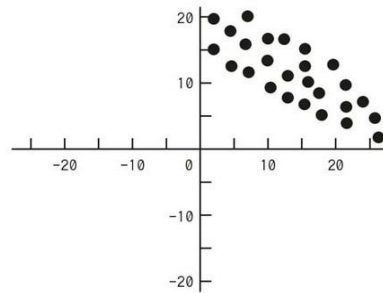
問47 散布図のうち，“負の相関”を示すものはどれか。

(解説p.482)

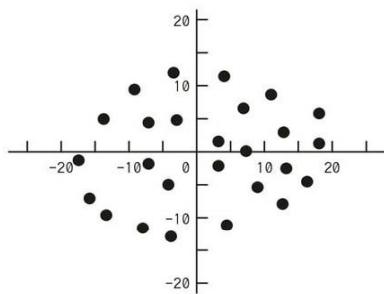
ア



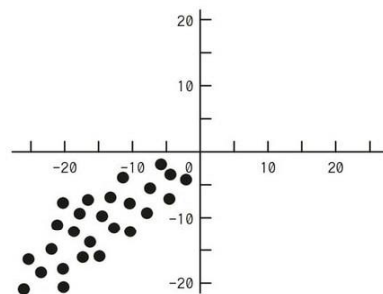
イ



ウ



エ



問48 マーケットバスケット分析の説明はどれか。

(解説p.482)

- ア POSシステムなどで収集した販売情報から、顧客が買物をした際に同時に購入した商品の組合せを見つける。
- イ 網の目状に一定の経線と緯線で区切った地域に対して、人口、購買力など様々なデータを集計し、より細かく地域の分析を行う。
- ウ 一定の目的で地域を幾つかに分割し、各地域にオピニオンリーダーを選んで反復調査を行い、地域の傾向や実態を把握する。
- エ 商品ごとの販売金額又は粗利益額を高い順に並べ、その累計比率から商品を三つのランクに分けて分析し、売れ筋商品を把握する。

▶ 模擬問題 〈科目B〉



出題数：12問（全問解答必須）

試験時間：120分（両科目）

問49

解説 p.483

模擬問題

〈科目B〉

J社は、従業員数90名の生活雑貨販売会社であり、店舗とECサイト（以下、J社のECサイトをJサイトという）で生活雑貨を販売している。EC営業部のCさんは、同部の情報セキュリティリーダーに任命されている。

〔Jサイトの情報セキュリティ対策〕

顧客用アカウントとその認証の仕様は顧客の利便性を考慮し、次のようになっている。

- 利用者IDとパスワードの組み（以下、利用者IDとパスワードの組みを認証情報という）を採用
- パスワードは8文字以上で英数字混在が必要
- 顧客が登録している情報を確認又は変更する際には認証情報の再入力が必要
- 新規にアカウントを登録する際に、既に使われている利用者IDを指定すると、使用されている旨を画面に表示
- 顧客用アカウントをもっていない者でも問合せを投稿できるようにするために、問合せを投稿する際には利用者認証が不要

〔情報セキュリティインシデントの発生〕

今回のインシデントについて、情報システム部のU部長及びカスタマサポート部のM部長から調査結果が表1のとおり報告された。

表1 調査結果

攻撃	調査結果
攻撃1	Jサイトの2018年10月からのログインログを確認したところ、2018年11月5日の3:00～4:00に海外のあるIPアドレスから、不正ログインの試みと思われる攻撃が980件の顧客用アカウントに対して1件ずつあり、その全てがJサイトに実在する顧客用アカウントに対するものであった。980件の不正ログインの試みのうち、90件が成功していた。

情報セキュリティ委員会は、EC営業部のE部長に対し、表1の攻撃について、対策を検討するよう指示した。E部長はCさんと協力し、対策を検討した。

〔追加の対策の検討〕

Cさんは、追加の対策として、表1の攻撃を早期に検知するために監視することにし、監視すべき値を表2にまとめた。これらの値が単位時間当たり一定数以上となった場合、EC営業部の情報セキュリティ責任者と情報セキュリティリーダーにメールで通知する。

表2 監視すべき値

攻撃	監視すべき値
攻撃1	i

設問 表2中の に入れる字句はどれか。解答群のうち、最も適切なものを選び。

解答群

- ア WAFが検知した攻撃のうちJサイトの脆弱性を悪用した攻撃の数
- イ カスタマサポート部に入った電話での問合せ数
- ウ 同一IPアドレスからの問合せフォームへのアクセス数
- エ 同一の顧客用アカウントについて一定数以上のIPアドレスから試行したログイン数
- オ 同一の顧客用アカウントについて失敗したログイン数
- カ 複数の顧客用アカウントについて同一のIPアドレスから試行したログイン数

F社は従業員数300名の高級家具卸販売会社である。

〔コールセンタの情報セキュリティ対策の検討〕

通信販売事業における消費者からの問合せ増加に伴い、別の事業所で通販事業部専用のコールセンタを立ち上げることになった。F社従業員の一部を配置転換するとともに、新たに20人のパート又はアルバイトを雇用してコールセンタ要員とする。さらに、新製品の発売などで問合せが増加した際には、臨時で短期間のアルバイトを雇用する。W氏は、N部長に依頼され、コールセンタでの情報セキュリティ対策案（表3）を作成した。

表3 コールセンタでの情報セキュリティ対策案

No	脅威	対策
1	コールセンタ要員以外の者が侵入する。	・
2	コールセンタ要員が記憶媒体を持ち込み、情報を窃取する。	（省略）
3	コールセンタ要員がノートPC を盗み出す。	（省略）

設問 表3中の に入れる対策として考えられるものは次のうちどれか。考えられる理由として適切なものだけを全て挙げた組合せを、解答群の中から選べ。

- （一） 入り口の外にロッカーを設置し、私物をそこに預け、業務上必要な物だけを透明なバッグに入れて執務室に出入りするようにする。
- （二） コールセンタ内での記憶媒体の使用を禁止する。
- （三） 出入口に警備員を配置し、入館証チェックや持ち物チェックを行う。
- （四） ネックストラップ式の入館証をコールセンタ要員に貸与し、着用させる。
- （五） ノートPCの画面にプライバシーフィルタを装着する。
- （六） ノートPCをセキュリティケーブルで机に固定する。
- （七） ホスト型侵入検知装置（HIDS）を設置する。

解答群

- | | | |
|---------------|---------------|-----------|
| ア （一），（二） | イ （一），（二），（三） | ウ （一），（三） |
| エ （一），（三），（六） | オ （二），（三） | カ （三），（四） |
| キ （三），（四），（六） | ク （四），（七） | ケ （五），（六） |
| コ （七） | | |

R社は従業員数600名の投資コンサルティング会社である。R社では顧客の個人情報（以下、顧客情報という）を取り扱っていることから、情報セキュリティの維持に注力している。

R社ネットワークではURLフィルタリングを導入しており、フリーメールサービスを提供するWebサイトやソフトウェアのダウンロードサイトへのアクセスを禁止している。また、従業員にノートPC又はデスクトップPCのどちらかを貸与しており、それらのPC（以下、貸与PCという）ではUSBメモリを使用できないようにしている。貸与PCのうち、ノートPCだけが、リモート接続サービスによる社内ネットワークへの接続を許可されている。

海外営業部の部員は10人で、顧客は500人弱である。各部員は、担当顧客に、電子メールや電話を使って営業を行っている。海外営業部は他の営業部のオフィスとは離れた海外営業部専用のオフィスで業務を行っている。海外営業部で使用している顧客管理システム（以下、Cシステムという）は、海外営業部だけが使用している。Cシステムでは、アクセスログを3か月分保存している。海外営業部の部員は、出張がなく、全員がデスクトップPCだけを使っている。

海外営業部では、情報システム部が運用管理を行っているファイルサーバを使用しており、各部員は顧客情報を含むファイルを当該ファイルサーバに一時的に保存する場合がある。その場合は、ファイルのアクセス権を各部員が最小権限の原則に基づいて設定することになっている。R社では、顧客情報を保護するために、次の2点を各担当者が定期的に確認することとなっている。

- ファイルサーバに不要な顧客情報を保存していないか。
- ファイルのアクセス権は適切に設定されているか。

R社では、情報セキュリティ推進部が実施する情報セキュリティ教育があり、海外営業部では、新たに配属された部員だけが受講することになっている。教育終了後には試験があるが、1回では合格できず、再度教育と試験を受ける部員が時々いる。この教育資料は、世の中で新たなセキュリティ脅威が発見される都度、情報セキュリティ推進部で更新している。

〔統制自己評価の実施〕

海外営業部にも監査部から統制自己評価を実施するよう依頼があり、W氏が海外営業部の評価を行うことになった。W氏は、監査部から送付されてきた統制自己評価シートに従って、職場の状況を観察したり、部員にヒアリングしたりして評価を行った。評価結果を表3に示す。統制自己評価シートの評価結果は次のルールに従って記入する。

- ・評価項目どおりに実施している場合：“OK”
- ・評価項目どおりには実施していないが、代替コントロールによって、“OK”の場合と同程度にリスクが低減されていると考える場合：“(OK)”（代替コントロールを具体的に評価根拠欄に記入する。）
- ・評価項目どおりには実施しておらず、かつ、代替コントロールによって評価項目に関するリスクが抑えられているわけではないと考える場合：“NG”
- ・評価項目に関するリスクがそもそも存在しない場合：“NA”

表3 統制自己評価シート（海外営業部の評価結果）（抜粋）

No.	評価項目	評価結果	評価根拠
11	リモート接続のためのパスワードを90日ごとに変更している。	b	
25	業務用アプリケーションの利用者IDの登録・変更・削除をルールどおり実施している。	OK	承認済みの利用者ID登録申請書を証跡として添付。

設問 表3中の b に入れる字句はどれか。解答群のうち、最も適切なものを選び。

bに関する解答群

	評価結果	評価根拠
ア	OK	会社のルールで決められている。
イ	NG	誰も1回も変更をしていない。
ウ	NG	リモート接続ができない。
エ	NA	部内ではリモート接続は誰も行わない。

F社は従業員数300名の高級家具卸販売会社である。

〔D事業所のレイアウト変更〕

F社は、今年、通販事業部を新設し、消費者に直接通信販売する新規事業を開始した。通販事業部は、本社から離れた所にある平屋建てのD事業所を卸事業部とともに使用している。D事業所では、卸事業部の人数と通販事業部の人数を合計して40名の従業員が働いている。これまでF社は、個人情報ほとんど取り扱っていなかったが、通信販売事業が順調に拡大し、複合機で印刷した送り状など、顧客の個人情報を大量に取り扱うようになってきた。そこで、通販事業部のN部長は、情報セキュリティを強化するために、オフィスレイアウトの変更を本社の総務部に依頼することにした。

これまでF社では、D事業所の事業部エリアへの入退室時に何のチェックもしていなかった。そこで、D事業所で働く全ての従業員にICカード機能を備えた従業員証を新たに配布した上で、通販事業部の従業員だけが通販事業部エリアに入退室できるようにした。具体的には、オフィスレイアウトを変更し、通販事業部エリアの出入口に、ICカード認証でドアを解錠するシステム（以下、ICカードドアという）を設置することにした。D事業所の新たなオフィスレイアウトを図1に示す。

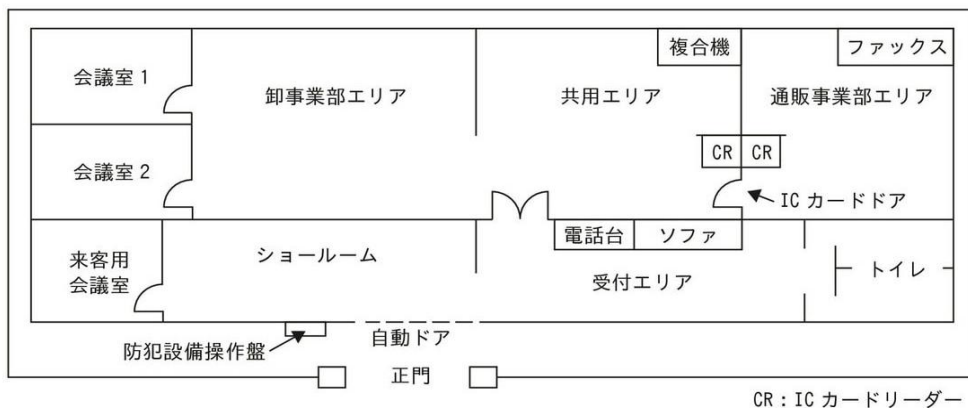


図1 D事業所の新たなオフィスレイアウト

〔新たなオフィスレイアウトでの業務観察〕

レイアウト変更の工事が終了し、新たなオフィスレイアウトでの業務が開始された。N部長は、D事業所の情報セキュリティリーダである通販事業部のW氏に、新たなオフィスレイアウトにおける業務運用に情報セキュリティ上の問題がないかどうかを改めて確認し、問題がある場合は改善の提案をするように指示した。W氏が新たなレイアウトでの業務を観察したところ、表1に示す三つの問題点が発見された。

表1 W氏が発見した問題点

問題点番号	問題点
問題点1	(省略)
問題点2	通販事業部が、ファックスで受信した注文書、商品発送時の送り状の控えなど、個人情報記録された紙媒体を大量に保有しているが、十分な管理がされていない。
問題点3	(省略)

そこでW氏は、各問題点に対する改善案を自ら検討し、あわせて、業務に日々従事しているD事業所の従業員からも意見を広く募り、それらを取りまとめることにした。

設問 問題点2の改善策として適切なものだけを全て挙げた組合せを、解答群の中から選べ。

- (五) 個人情報記録された紙媒体は、業務上の必要の有無にかかわらず、1週間以内に細断し、廃棄する。細断するまでは、キャビネットに施錠保管する。
- (六) 新たに文書管理システムを導入し、個人情報記録された紙媒体は、スキャナで電子化して適切に管理する。不要となった紙媒体は細断し、廃棄する。
- (七) 個人情報記録された紙媒体は、バイндаにとじた上で、機密情報であることが分かるように機密区分を明示し、キャビネットに施錠保管する。
- (八) 個人情報記録された紙媒体は、どこにあるか分からないように、他の文書と混ぜて机の上に並べる。

解答群

- | | | | |
|------------|------------|------------|-------|
| ア (五) | イ (五), (七) | ウ (五), (八) | エ (六) |
| オ (六), (七) | カ (六), (八) | キ (七) | ク (八) |

K社は、IT製品の卸売会社であり、300社の販売店に製品を卸している。K社では、8年前に従業員が、ある販売店向けの奨励金額が記載されたプロモーション企画書ファイルを添付した電子メール（以下、メールという）を、担当する全販売店の担当者宛てに誤送信するというセキュリティ事故が発生した。この事故を機に、メールの添付ファイルを、使い捨てのパスワード（以下、DPWという）によって復元可能なZIPファイルに変換する添付ファイル圧縮サーバを導入した。K社では、ファイルの受渡しが業務運営上欠かせない。

添付ファイル圧縮サーバ導入後のメール送信手順を図1に示す。

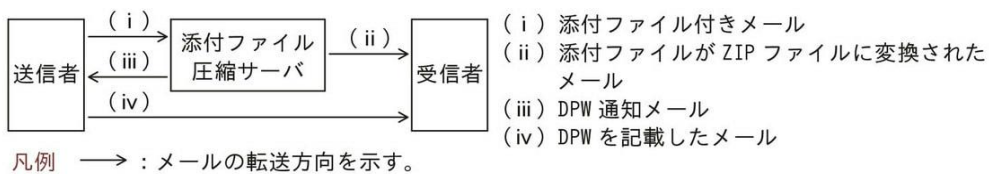


図1 添付ファイル圧縮サーバ導入後のメール送信手順

〔現在のメール運用の問題点と対策〕

K社では、添付ファイル圧縮サーバを利用して、最初にDPWで復元可能なZIPファイルを添付したメール（以下、本文メールという）を送信し、その後、ZIPファイルを復元するためのDPWを記載したメール（以下、PWメールという）を送信することによって、メールのセキュリティを確保する方式（以下、この方式をPPAPという）を運用している。

しかし、現在運用しているPPAPは、政府のある機関において中止するという方針が公表され、K社の販売店や同業者の中でもPPAPの運用を止める動きが見られるようになった。

このような状況から、K社の情報セキュリティ委員会は、自社のPPAPの運用上の問題点を検証することが必要であると判断して、情報セキュリティリーダーのL主任に、PPAPの運用上の問題点の洗い出しと、その改善策の検討を指示した。

L主任は、現在のPPAPの運用状況を調査して、次の二つの問題点を洗い出した。

- (1) 本文メールの宛先を確認せずに、本文メールと同じ宛先に対してPWメールを送信している従業員が多い。
- (2) ほとんどの従業員が、PWメールを本文メールと同じメールシステムを使用して送信している。したがって、本文メールが通信経路上で何らかの手段によって盗聴された場合、PWメールも盗聴されるおそれがある。

設問 PPAPの対策として考えられるものは次のうちどれか。考えられる理由として適切なものだけを全て挙げた組合せを、解答群の中から選べ。

- (一) DPWを、電話や携帯メールなど異なった手段で伝える。
- (二) DPWでなく、ワンタイムパスワードで復元可能なZIPファイルを添付したメールを本文メールとして送信する。
- (三) 本文メールを受信した際に、メールソフトで「添付ファイルを削除しました」と表示する機能を利用する。
- (四) ファイルの受渡しをすべて手渡しで行うようにする。
- (五) 認証機能のあるクラウドストレージサービスに受渡しをしたいファイルを格納し、両者で利用する。

解答群

- | | | |
|-----------------|-----------------|-----------------|
| ア (一), (二) | イ (一), (二), (五) | ウ (一), (三) |
| エ (一), (三), (五) | オ (二), (三) | カ (二), (三), (四) |
| キ (二), (五) | ク (三), (四) | ケ (三), (四), (五) |
| コ (三), (五) | | |

P社は、従業員数1,200名の大学受験及び高校受験のための大手予備校である。先日開催した経営会議において、次年度から中学受験向けコースの事業部（以下、C事業部という）を新たに立ち上げることが決まり、現在、開講に向けた準備作業を進めている。C事業部は、教務部、営業部、総務部、マーケティング部の計4部で構成され、マーケティング部は、市場調査、広報活動、外部公開のWebサービスの企画、導入、運用などを担当している。

〔情報セキュリティの重点方針〕

現在、P社の最高情報セキュリティ責任者（CISO）は、情報セキュリティ活動を推進し情報を守ることと、情報を活用しビジネスを成長させることの両立が必要不可欠であると考えている。そこで、P社の情報セキュリティの重点方針として、“個人情報の漏えい防止”と“Webサービスの継続性確保”の2点を定めて、情報セキュリティ委員会のメンバに通知している。

〔Webサービスの仕様〕

C事業部のマーケティング部では、模擬試験の結果速報、成績推移などを、P社の中学受験向けコースに通う児童（以下、児童という）、及び児童の保護者（以下、保護者という）が閲覧できるように、ログイン機能を有したWebサービス（以下、Wサービスという）をWebアプリケーションソフトウェア（以下、Webアプリという）として開発し、提供することを検討している。マーケティング部のNさんは、Wサービスの企画を担当している。図1は、Nさんが作成したWサービスの仕様案である。

1. サービスメニューの概要

- (1) 模擬試験の結果速報
- (2) 成績推移
- (3) 料金の自動引落とし明細

2. 認証機能

(1) ログイン

任意に設定できる英数字の利用者IDと数字4桁の児童用パスワードを使用してログインする。

(2) アカウントロック

5回連続してログインに失敗すると、1分間、アカウントをロックする。

(3) 保護者用パスワードによる追加ログイン

料金の自動引落し明細メニューにアクセスするためには英数記号8文字以上の保護者用パスワードによる追加ログインを必要とする。

(4) ログアウト

“ログアウト” ボタンをクリックするとログアウトする。“ログアウト” ボタンを押さない限り、ログインしたままとする。

(5) パスワードの表示

児童用パスワードも保護者用パスワードも、パスワード入力内容の表示、非表示を切り替えられるようにする。初期状態は、非表示とする。

図1 Wサービスの仕様案（抜粋）

マーケティング部の情報セキュリティリーダーであるS主任は、Nさんが作成したWサービスの仕様案を情報セキュリティの観点からレビューした。

次は、S主任とNさんとの会話である。

S主任：模擬試験の結果などが児童本人及びその保護者以外に閲覧されるリスク（以下、閲覧リスクという）を減らすために、Wサービスはログイン機能を実装することになっていたね。

Nさん：はい。児童でも覚えやすい数字4桁のパスワードを用いる仕様です。

S主任：料金の自動引落し明細メニューのログインについても教えてくれないか。

Nさん：こちらは、保護者がアクセスします。児童が閲覧する必要はないことから、英数記号8文字以上の保護者用パスワードで追加ログインする仕様です。また、パスワードの入力間違いを減らすために、保護者がパスワード入力内容を表示に切り替えて、入力内容を確認することができます。

S主任：よく分かった。この仕様案では、ブルートフォース攻撃のリスクが大きいね。また、児童の場合、自分専用のPCをもっているケースは少ないと思うよ。図書館、学校などの共用PCを利用することが多く、そこでログアウトを忘れることもあるので、閲覧リスクが大きいね。

S主任は、レビュー後に、次の2点の変更、追加をNさんに指示した。

- ブルートフォース攻撃のリスクを低減するために機能の仕様を変更する。
- ②共用PCにおける閲覧リスクを低減するために機能を追加する。

設問 本文中の下線②について，追加すべき機能はどれか。解答群のうち，最も適切なものを選べ。

解答群

- ア アカウントロックを利用者が自ら解除できる機能の追加
- イ 定期的なパスワード変更を利用者に促すメッセージ機能の追加
- ウ パスワード強度をチェックする機能の追加
- エ パスワードを忘れた際に使う利用者への“秘密の質問”機能の追加
- オ マルウェア検知機能の追加
- カ ログイン状態をタイムアウトさせる機能の追加

R社は、インターネット上でショッピングモール（以下、ECサイトという）を運営する、従業員数3,000名の企業である。ECサイトの総店舗数は5,000店、会員数は300,000名である。R社には、情報システム部、開発部、サポート部、営業部及び総務部がある。

〔不審な通信の発見〕

情報システム部では、セキュリティ監視業務の一環として8時間ごとにプロキシサーバのアクセスログを確認している。ある日の正午過ぎ、その日の午前4時から正午までのプロキシサーバのアクセスログの集計情報を確認していた情報システム部のU君は、特定の社内PCから特定のサーバに多数のHTTPS通信が行われていることを発見した。U君は不審に思い、アクセスログを急いで調査した結果、次のことが判明したので、それを午後0時30分に情報システム部のT部長に報告した。

- 1台の事務用PCから、社外の同一サーバ（以下、被疑サーバという）に対して多数のHTTPS通信が、およそ30分おきに行われている。
- HTTPS通信が行われるごとに、数100kバイトのデータを送信している。

〔インシデントへの初動対応〕

報告を受けたT部長は、インシデントが発生したと判断して、情報システム部内に設置されているCSIRTの責任者であるV課長に対してインシデント対応を開始するよう指示した。V課長は、CSIRTメンバのM君を呼び、対応を開始するよう指示した。M君は、図に示すインシデント対応規程に従って、初動対応を行った。

• PCからの不審な通信を発見した場合

- (1) 各種のログを調査して、不審な通信の送信元を特定する（以下、特定した送信元を不審PCという）。
- (2) 不審PCをLANから切り離す。電源オンの状態のまま移動できる場合は、直ちに解析室へ移動する。電源オンの状態のまま移動できない場合は、電源をオフにすると消去されてしまう情報について、必要な調査を電源オンの状態で行い、調査終了後、電源をオフにして直ちに解析室へ不審PCを移動する。
- (3) 不審な通信を行っているPCが他にないか確認する。同様の通信を行っているPCを発見した場合は、不審PCと同じ対処をする。
- (4) 解析室内でマルウェア感染の可能性について初期判定を行う。
- (5) 不審PCを利用していた部署に初期判定結果を報告する。
- (6) 初期判定でマルウェアの可能性ありと判定したら、マルウェアの動作を特定するために詳細解析を開始する。
- (7) 特定されたマルウェアの動作から、被害の有無及び影響範囲を確認するとともに、被害拡大を防ぐために必要な措置を決定し、実施する。

図 インシデント対応規程（抜粋）

設問 不審PCをLANから切り離さない場合、マルウェアがどのような活動をする想定されるか。想定される適切な活動だけを全て挙げた組合せを、解答群の中から選べ。

- (一) 不審PC内のファイルを暗号化する。
- (二) 不審PC内のソフトウェアを勝手に実行する。
- (三) R社のLANにマルウェアの感染を拡大する。
- (四) R社の情報をインターネットに送信する。

解答群

- | | | | |
|------------|------------|------------|------------|
| ア (一) | イ (一), (二) | ウ (一), (三) | エ (一), (四) |
| オ (二) | カ (二), (三) | キ (二), (四) | ク (三) |
| ケ (三), (四) | コ (四) | | |

A社は、小、中、高校生及び大学受験生向けに通信教育を行っている。A社では、受講生の個人情報や受講履歴などを管理する受講生管理システムと複数の業務システム（以下、A社の各種システムという）をE社のデータセンタで運用している。A社の各種システムの運用管理は、社内のシステム運用管理室で、F社から派遣された技術者（以下、F社技術者という）が行っている。

メール管理システムは、電子メール（以下、メールという）の誤送信を防止する目的で導入されている。PCから送信されたメールは、メール管理サーバで一旦保留され、送信者によって、宛先、メール本文及び添付ファイルに間違いがないことの確認操作が行われた後に、メールサーバに転送される。インターネットアクセスは、プロキシサーバ経由で行う。

A社では、情報セキュリティ担当役員を委員長とする情報セキュリティ委員会によって、情報セキュリティ管理規程（以下、管理規程という）が整備されている。社員は、社外の関係者との間で、添付ファイル付きメールの送受信を行っている。業務上不要なWebサイトへのアクセスやメールの私的利用は禁止されているが、徹底できていない。

昨今、正社員や派遣社員など、内部者の不正行為による個人情報や営業情報の漏えい事件の報道が後を絶たない。そこで、情報セキュリティ委員会では、内部不正による情報漏えいの追加の対策を実施することを決め、A社の情報セキュリティリーダーのB主任に、情報システム部の支援を受けて対策案をまとめるように指示した。

〔現状の調査〕

B主任は、まず、内部不正が発生する要因について調査した。次の三つの問題があることが判明した。

- (1) (省略)
- (2) メールや社外のWebサイトの利用が、管理規程どおりに行われていない。
- (3) (省略)

これらの問題への対策を実施することによって、不正のトライアングルの要因の一つである機会が低減されることから、不正の抑止につながると考えられるので、これらの問題への対策について検討することにした。

〔内部不正に対する技術面での対策〕

問題の(2)については、メール管理システムとプロキシサーバの設定の見直しで対処することにした。導入済みのメール管理システムの未使用の機能を図2に示す。

1. 情報漏えい対策機能

 - ②添付ファイル付きメールに対して、指定された処理を行う。

図2 メール管理システムの未使用の機能（抜粋）

メール管理システムでは、新たに、図2中の情報漏えい対策機能を有効にする。

設問 図2中の下線②の“指定された処理”について、A社の業務内容を考慮した場合、最も適切な処理の内容を解答群の中から選べ。

解答群

- ア あらかじめ指定された上司に通知し、上司の承認後に送信する。
- イ 一旦保留し、送信者によるメール内容の確認操作後に送信する。
- ウ 添付ファイルを暗号化し、パスワードを別メールで送信する。
- エ 添付ファイルを削除して、メールの本文だけを送信する。

Q社は、従業員数300名の保険代理店であり、生命保険会社2社、損害保険会社2社と代理店委託契約を締結し、保険商品を販売している。

〔内部不正事案の発生〕

T営業所のJ主任が3月31日付で退職したいと申し出た。H主任は、従業員退職時の点検手続に従って、J主任が退職申出日の1か月前からこれまでに社外に送信したメールをチェックした。Q社では、情報セキュリティ関連規程で会社の秘密情報の社外持出しを原則禁止するとともに、万一持ち出したものがあれば全て返却した旨を退職者に退職時の誓約書で誓約させている。

チェックの結果、J主任の私用と思われるメールアドレス宛てに、ファイルが5回送信されていることが分かった。送信されたファイルは、暗号化されていた。H主任は、分かったことをすぐに営業部長に報告した。営業部長は、総務部長及びK所長に連絡し、H主任とともにT営業所に赴いた。営業部長とK所長は、J主任に面談して事情を確認した。その後、営業部長は、K所長とも面談した。J主任との面談結果を図4に、K所長との面談結果を図5に示す。

2. 私用のメールアドレス宛てに顧客ファイルを送信した理由、状況

J主任は、次のように考えた。

- 試行期間中にT営業所で担当している全顧客情報が顧客システムに登録されたが、その中には自分が担当する顧客の情報も多くあるので、退職後ももっていても構わない。
- 同業他社に転職したときに、営業所の全顧客情報を利用して営業で良い成績を上げたい。
- 登録された顧客情報を利用することはQ社に迷惑を掛けるようなことではないし、後ろめたいようなことでもない。
- K所長は外回りなどで多忙なので、メールの確認は余りしていないようであり、またスタッフも様々な事務で忙しそうであったので、見つかりはしない。

3. 退職理由など

他チームの営業成績が良い中で、自分のチームだけノルマが達成できず、J主任は孤独を感じていた。今の状況では自分の実力を発揮できず公平に評価もされないが、同業他社に転職すればもっと実力を発揮でき、評価されると考えた。ただし、他社との雇用契約は未締結。

図4 J主任との面談結果（抜粋）

3. 教育など

顧客システムの試行終了時に、顧客ファイルをPCから消去するよう、開発チームから連絡があり、K所長からも営業所内に周知したが、K所長は試行利用者のPCの中までは点検しなかった。

図5 K所長との面談結果（抜粋）

〔事案の原因分析〕

H主任とG主任は、事案発生までの顧客システムやメールの取扱い、J主任及びK所長との面談結果から、“不正のトライアングル”を基に、表2のとおり、J主任の立場から見た事案の原因を整理した。

表2 “不正のトライアングル”を基にした原因の整理

項番	要因	事案の原因
1	動機・プレッシャ	• c (省略)
2	機会	• 顧客システムから顧客情報を大量にダウンロードできたこと • メールに顧客ファイルを添付して、私用のメールアドレス宛てに送信できたこと (省略)
3	正当化	(省略)

注記 要因の分類は、米国の組織犯罪研究者ドナルド・R・クレッシーによる。

設問 表2中の c に入れる字句はどれか。解答群のうち、最も適切なものを選び。

cに関する解答群

- ア Q社が、自分のことを公平に評価してくれないので、営業成績を悪化させて損害を与えたいと考えたこと
- イ T営業所が担当する顧客情報には、自分が担当する顧客の情報も多くあり、退職後ももっていても構わないと考えたこと
- ウ 営業所長が多忙で、不在なときが多く、メールの確認が十分に行われていなかったこと
- エ 顧客情報を持ち出して利用すれば、転職先で実力が発揮できて高く評価されると考えたこと
- オ 顧客ファイルを会社のPCに保管し続けることができたこと

T社は従業員数200名の建築資材商社であり、本社と二つの営業所の3拠点がある。このうち、Q営業所には、業務用PC（以下、PCという）30台と、NAS1台がある。

NASは、Q営業所の営業課と総務課が共用しており、課ごとにデータを共有しているフォルダ（以下、共有フォルダという）と、各個人に割り当てられたフォルダ（以下、個人フォルダという）がある。個人フォルダの利用方法についての明確な取決めはないが、PCのデータの一部を個人フォルダに複製して利用している者が多い。

Q営業所と本社はVPNで接続されており、営業所員は本社にある業務サーバ及びメールサーバにPCからアクセスして、受発注や出荷などの業務を行っている。

T社には、本社の各部及び各課の責任者、並びに各営業所長をメンバーとする情報セキュリティ委員会が設置されている。Q営業所の情報セキュリティ責任者はK所長、情報セキュリティリーダーは、総務課のA課長である。

〔マルウェア感染〕

ある土曜日の午前10時過ぎ、自宅にいたA課長は、営業課のBさんからの電話を受けた。休日出勤していたBさんによると、BさんのPC（以下、B-PCという）を起動して電子メール（以下、メールという）を確認するうちに、取引先からの出荷通知メールだと思ったメールの添付ファイルをクリックしたという。ところが、その後、画面に見慣れないメッセージが表示され、B-PCの中のファイルや、Bさんの個人フォルダ内のファイルの拡張子が変わってしまい、普段利用しているソフトウェアで開くことができなくなったという。これらのファイルには、Bさんが手掛けている重要プロジェクトに関する、顧客から送付された図面、関連社内資料、建築現場を撮影した静止画データなどが含まれていた。そこで、BさんはT社の情報セキュリティポリシー（以下、ポリシーという）に従ってA課長に連絡したとのことであった。

A課長は、B-PCにそれ以上触らずそのままにしておくようBさんに伝え、取り急ぎ出社することにした。

A課長がQ営業所に到着してB-PCを確認したところ、画面にはファイルを復元するための金銭を要求するメッセージと、支払の手順が表示されていた。A課長は、B-PCがマルウェア

アに感染したと判断し、K所長に連絡して、状況を報告した。この報告を受けたK所長は、インシデントの発生を宣言した。また、Bさんは、A課長の指示に従ってB-PCとNASからLANケーブルを抜いた。

〔対策の見直し〕

今回のインシデントを受けて、T社の情報セキュリティ委員会が開催された。A課長は、CISOから、今回のインシデントに関する問題点は何かと尋ねられた。A課長は、データの取扱い及びバックアップに関するルールの内容が不十分であったことが問題点であったと回答し、次のことを提案した。

- データの取扱い及びバックアップに関するルールを全面的に見直し、全社的なルールを定めること
- 営業所でのNASの利用は半年以内に廃止すること
- NASの利用を暫定的に継続する間は、営業所では今回の種類のマルウェアに感染することによってファイルが暗号化されてしまうという被害に備えたバックアップを実施し、あわせて⑥バックアップ対象のデータの可用性確保のための対策を検討すること

これらの提案は情報セキュリティ委員会で承認された。T社はマルウェア感染を契機として情報セキュリティの改善を図ることになった。

設問 本文中の下線⑥について、次の（一）～（四）のうち、効果があるものだけを全て挙げた組合せを、解答群の中から選べ。

- （一） バックアップした媒体からデータが正しく復元できるかテストする。
- （二） バックアップした媒体を二つ作成し、一つは営業所に、もう一つは別の安全な場所に保管する。
- （三） バックアップした媒体を再び読み出せないようにしてから廃棄する。
- （四） バックアップする際にデータに暗号化を施す。

解答群

- | | | |
|---------------|-----------|---------------|
| ア （一） | イ （一），（二） | ウ （一），（二），（三） |
| エ （一），（四） | オ （二） | カ （二），（三） |
| キ （二），（三），（四） | ク （二），（四） | ケ （三） |
| コ （三），（四） | | |

Z社は、従業員数2,000名の生命保険会社であり、東京に本社をもち、全国に支社が点在している。以下、本社及び各支社を拠点という。

Z社では、拠点の営業員が、会社貸与の持出し用ノートPC（以下、NPCという）を携帯して顧客を訪問し、商品説明資料、見積書、契約書の作成などを行っている。NPCではクラウドサービスで提供される契約管理システムを利用している。

Z社は、各拠点に情報セキュリティ管理責任者とその配下の情報セキュリティリーダを置いている。また、各拠点に配置された情報システム担当は、各拠点で利用するPCなどの情報機器の貸出し、持出し管理の実施指導、本社情報システム部と連携した情報システムの運用管理、利用支援などを行っている。情報セキュリティ対策を施したNPCに“対策済NPC”の文字列と有効期限日（最長6か月）を記載したシールを貼り付ける。

Z社の情報セキュリティ管理規程では、顧客情報を含めZ社が秘密として管理している情報（以下、秘密情報という）の漏えい及びその可能性がある情報セキュリティインシデント（以下、情報セキュリティインシデントをインシデントという）が発生した場合の対応手順を定めている。そのうち、従業員に貸与している情報機器の紛失・盗難が発生した場合の対応手順は図1のとおりである。

1. インシデントの発生

紛失・盗難の発生又はその可能性がある事象を発見した従業員は、直ちに、所属する部課（以下、当該部課という）の長に報告する。報告を受けた長は、直ちに、その時点で確認した事実関係を、当該部課がある拠点（以下、当該拠点という）の情報セキュリティ管理責任者に報告する。情報セキュリティ管理責任者は、情報機器への不正なアクセスのおそれ、秘密情報の紛失・漏えいの発生又はその可能性があるかと判断した場合には、インシデントの発生を宣言する。

2. 初動対応

情報セキュリティ管理責任者は、配下の情報セキュリティリーダに対して、直ちに、初動対応の体制の編成及び初動対応の開始を指示する。情報セキュリティリーダは、当該拠点の情報システム担当と協力して、インシデントの事実関係を整理し、情報機器に保存されていた情報の内容及び量、並びに暗号化、アクセス制御などの情報セキュリティ対策の実施状況を確認する。保存されていた情報に情報システムのアカウント情報が含まれる場合は、パスワードの変更やアカウントの停止を行うなど、インシデントの影響拡大を防止する措置をとる。情報セキュリティリーダは、確認結果と防止措置を当該拠点の情報セキュリティ管理責任者に報告する。情報セキュリティリーダは、必要に応じてインシデントの対応に当たるメンバを指名することができる。

以下省略（“3. 調査”，“4. 通知，報告及び公表”，“5. 復旧”，“6. 事後対応”が続く）。

図1 情報機器の紛失・盗難発生時の対応手順（抜粋）

〔情報機器の紛失〕

R支社は、従業員数100名の支社であり、営業員が60名いる。R支社では、支社長が情報セキュリティ管理責任者を務め、各部課の長が情報セキュリティリーダを務めている。

10月12日（水）10時30分頃、R支社の営業部1課のFさんが、客先からR支社に戻る途中、電車の網棚にかばんを置き忘れるという事象が発生した。かばんの中には、NPCが入っていた。

報告を受けたR支社長は、インシデントの発生を宣言し、営業部1課の情報セキュリティリーダであるK課長に対して、直ちに初動対応を開始するよう指示した。また、R支社長の指示によって、K課長、各部の部長、及びR支社の情報システム担当として初動対応に当たるW主任が出席して、インシデント対策会議が開催されることとなった。

幸い、当日の15時頃にかばんと其中的NPCを回収することができた。しかし、紛失している間に、外部の者によってNPCを操作されたり、NPCから情報を窃取されたりした可能性は否定できない。K課長は、調査を継続しつつ、16時30分に開催予定のインシデント対策会議に向けてインシデント報告書案を作成することにした。

〔インシデント報告書案の作成〕

Fさんが置き忘れた情報機器（以下、紛失機器という）の資産管理番号はZR00XXXXで、10月3日に1か月間のNPC期間持出しを承認した記録があった。K課長は、インシデント報告書案の一部として、初動対応の経緯を図2のとおり整理した。

(2) 初動対応		
11:00	K課長	関係者を召集して状況説明。初動対応を次のとおり開始。 (a) K課長の実施内容 ・紛失物の搜索活動の支援 ・情報機器紛失時の状況など，事実関係の確認 (省略) (b) W主任の実施内容 ・紛失機器の特定 (省略) ・ c システムの特定 ・上記で特定したシステムにおいてFさんのアクセス権の無効化 ・上記で特定したシステムにおいて社外から不審なアクセスがないかどうかの幅広い確認

図2 インシデント発生とその初動対応の経緯

設問 図2中の c に入れる字句はどれか。解答群のうち，最も適切なものを選び。

cに関する解答群

- ア Fさんがオフィスで使っている
- イ Fさんが外出先からアクセスできる
- ウ Fさんが顧客情報を保管している
- エ Fさんが顧客訪問の際に画面を見せてもらったことがある

マンション管理会社Q社は、マンションの管理組合から委託を受けて管理業務を行っており、契約している管理組合数は3,000組合である。東京の本社には、経営企画部、営業統括部、人事総務部、経理部、情報システム部、監査部などの管理部門があり、東日本を中心に30の支店がある。従業員数は、マンションの管理人（以下、管理員という）3,300名を含めて3,800名である。

U支店には、支店長、主任2名、管理組合との窓口を務めるフロント担当者10名が勤務している。U支店の情報セキュリティ責任者はB支店長、情報セキュリティリーダーは第1グループのA主任である。U支店に勤務する従業員には、一人1台のノートPC（以下、NPCという）が貸与されている。NPCにはデジタル証明書をインストールし、Q社のネットワークに接続する際に端末認証を行っている。

U支店が契約している管理組合数は80組合であり、フロント担当者1名当たり5～10の管理組合を担当している。U支店が担当する管理組合のマンションはそれぞれ、管理事務室が1か所設置されており、管理員が1～2名勤務している。管理事務室には、管理員以外に、Q社従業員、マンション居住者が立入ることがある。多くのマンションでは、管理事務室の入室にマンションごとの暗証番号が必要である。暗証番号はおおむね2年ごとに変更される。管理事務室には、管理組合の許可を受けた上で、管理員とU支店の連絡用に、LTE通信機能付きNPCを1台設置し、インターネットVPN経由でQ社のネットワークと接続している。①管理事務室に複数の管理員が勤務する場合には、管理員間でNPC、利用者ID、パスワード、メールアドレスを共用している。

設問 本文中の下線①について、次の（一）～（四）のうち、共用することによって高くなるリスクはどれか。該当するものだけを全て挙げた組合せを、解答群の中から選べ。

- （一） NPCを操作した者を特定できないという状況を狙われて、不正に操作されるリスク
- （二） 異動者や退職者など、利用資格を失った者にNPCを不正に操作されるリスク
- （三） 共用者の1人がパスワードを変更した際に、他の共用者に変更後のパスワードを伝えるためのメモを書き、そのメモからパスワードが漏えいし、不正に操作されるリスク
- （四） クリアスクリーンをし忘れ、その隙に不正に操作されるリスク

解答群

ア (一)

エ (一), (二), (四)

キ (一), (四)

コ (三), (四)

イ (一), (二)

オ (一), (三)

ク (二), (三)

ウ (一), (二), (三)

カ (一), (三), (四)

ケ (二), (四)

模擬問題

〈科目B〉